

RBAC Module

Role-Based Access Control — Permissions, Roles, and Modules.

Super Admin base paths: `/api/v1/admin/permissions` , `/api/v1/admin/roles` , `/api/v1/admin/modules`

Firm Admin base path: `/api/v1/firm/roles`

1. Permission Scopes

Scope	Who Can Receive	Example
GLOBAL	SUPER_ADMIN only	System config, audit settings
TENANT	FIRM_ADMIN and below	Most module permissions
ASSIGNED	ADVOCATE / PARALEGAL and below	Assigned cases, document upload
OWN	CLIENT only	Own records

2. System Roles

Role	Ceiling	Has Permissions For
SUPER_ADMIN	GLOBAL	All modules
FIRM_ADMIN	TENANT	Case Mgmt, Employee, Client, Billing, Documents, Calendar, Reports, Audit
ADVOCATE	ASSIGNED	Case view/edit, documents, calendar
PARALEGAL	ASSIGNED	Case view, documents, calendar view
CLIENT	OWN	Own case view, own documents

3. Permission Endpoints

Base: `/api/v1/admin/permissions` (Super Admin only)

Method	Path	Description
GET	<code>/api/v1/admin/permissions</code>	List all permissions

GET	/api/v1/admin/permissions/active	List only active permissions
GET	/api/v1/admin/permissions/{id}	Get permission by ID
POST	/api/v1/admin/permissions	Create or update a permission
DELETE	/api/v1/admin/permissions/{id}	Delete a permission
PATCH	/api/v1/admin/permissions/{id}/toggle	Toggle permission active status

```
Create/Update Permission Request:
{
  "data": {
    "id": null,           // null for create, UUID for update
    "code": "CASE_MANAGEMENT:VIEW",
    "action": "VIEW",
    "scope": "TENANT",
    "description": "Case Management - VIEW"
  }
}
```

4. Role Endpoints (Super Admin)

Base: `/api/v1/admin/roles`

Method	Path	Description
GET	/api/v1/admin/roles	List all roles with permissions
GET	/api/v1/admin/roles/active	List only active roles
GET	/api/v1/admin/roles/{id}	Get role by ID
POST	/api/v1/admin/roles	Create or update role (with permissionIds)
DELETE	/api/v1/admin/roles/{id}	Delete a non-system role
PATCH	/api/v1/admin/roles/{id}/toggle	Toggle role active status
POST	/api/v1/admin/roles/permissions	Assign permissions to a role
GET	/api/v1/admin/roles/{id}/permissions	Get permissions for a specific role

```
Create/Update Role Request:
{
  "data": {
    "id": "uuid-or-null",
    "name": "FIRM_ADMIN",
    "code": "FIRM_ADMIN",
    "description": "Manages law firm operations",
  }
}
```

```
    "permissionIds": ["uuid1", "uuid2", "..."]
  }
}

Assign Permissions to Role:
{
  "data": {
    "roleId": "uuid",
    "permissionIds": ["uuid1", "uuid2", "..."]
  }
}
```

5. Module Endpoints (Super Admin)

Base: `/api/v1/admin/modules`

Method	Path	Description
GET	/api/v1/admin/modules	List all modules
GET	/api/v1/admin/modules/active	List active modules
GET	/api/v1/admin/modules/{id}	Get module by ID
POST	/api/v1/admin/modules	Create or update module
DELETE	/api/v1/admin/modules/{id}	Delete a module
PATCH	/api/v1/admin/modules/{id}/toggle	Toggle module status
POST	/api/v1/admin/modules/{id}/permissions	Assign permissions to a module

6. Firm Role Endpoints (Firm Admin)

Base: `/api/v1/firm/roles`

Method	Path	Description
GET	/api/v1/firm/roles	List all firm-scoped roles
GET	/api/v1/firm/roles/{id}/permissions	Get role permissions + available permissions for picker UI
PUT	/api/v1/firm/roles/{id}/permissions	Update permissions for a firm role (ceiling enforced)

7. Scope Ceiling Rule

Enforced at assignment time. When assigning permissions to a role, the system checks if the permission's scope is within the role type's ceiling. A FIRM_ADMIN role (ceiling: TENANT) cannot receive GLOBAL-scoped permissions. Returns 403 with a descriptive message.